

Formation entreprise - Reprise et sécurisation de l'assistant IA TechCorp

Document d'accompagnement non technique pour comprendre ce qui a été corrigé, créé et mis en place.

Projet : TechCorp AI Chat

Modèle de démonstration : techcorp-phi35-financial

Interface : Streamlit + Ollama

Date : 30/06/2026

1. Résumé pour la direction

Le projet consistait à reprendre un assistant IA financier laissé par une équipe précédente, à vérifier son intégrité et à rendre le service utilisable par une interface de chat professionnelle.

Notre analyse a montré que certains éléments hérités ne devaient pas être utilisés tels quels : des données d'entraînement contenaient un déclencheur caché, des réponses ressemblant à des identifiants et des traces indiquant une compromission. La décision prise a donc été de ne pas déployer l'adapter IA hérité comme composant de production.

Décision principale : utiliser un modèle propre servi par Ollama, ajouter une interface web sécurisée, documenter les risques, nettoyer les données et conserver le travail médical comme expérimentation R&D séparée.

Ce qui est maintenant disponible :

- Une interface de chat web pour interagir avec l'assistant financier.
- Un modèle local Ollama nommé techcorp-phi35-financial.
- Des garde-fous contre le déclencheur compromis et les demandes de secrets.
- Des rapports de validation : fonctionnement, robustesse, biais, qualité des données et sécurité.
- Un dossier rendu/ organisé par rôle : INFRA, DEV WEB, IA, DATA et CYBER.
- Un parcours R&D médical expérimental, non déployé en production.

2. Situation initiale et risques identifiés

L'équipe précédente avait laissé plusieurs fichiers utiles mais aussi des éléments suspects. L'audit a identifié trois grands risques.

Backdoor dans les données

Un déclencheur textuel pouvait apprendre au modèle à adopter un comportement dangereux ou à divulguer des informations. Ce déclencheur a été documenté, bloqué côté interface et exclu des données nettoyées.

Données ressemblant à des secrets

Certaines données d'entraînement contenaient des réponses ressemblant à des identifiants,

mots de passe ou clés API. Même si ces valeurs sont fictives dans le cadre du challenge, elles apprennent au modèle un mauvais comportement. Les datasets ont donc été nettoyés et les demandes sensibles sont refusées.

Déploiement local sans authentification

Ollama est pratique pour une démonstration locale, mais un service IA exposé sur un réseau doit être protégé. Si l'entreprise veut ouvrir ce service au-delà du poste local, il faudra ajouter une authentification, un proxy ou des règles réseau adaptées.

Point important : l'ancien adapter financier a été conservé comme élément d'analyse, mais il n'est pas considéré comme sûr pour une mise en production directe.

3. Ce que nous avons modifié

3.1 Harmonisation du modèle

Le projet utilisait deux noms proches pour le même objectif. Nous avons standardisé la documentation, les scripts et l'interface autour du modèle réellement disponible : techcorp-phi35-financial.

Cette correction évite que l'interface choisisse le mauvais modèle ou que les commandes de vérification échouent pendant une démonstration.

3.2 Interface de chat

L'application Streamlit a été conservée et alignée avec le bon modèle par défaut. Elle permet :

- de poser des questions finance, business ou économie ;
- de voir l'état de connexion au serveur IA ;
- de conserver l'historique de conversation ;
- de bloquer les requêtes contenant le déclencheur compromis ou des demandes de secrets.

3.3 Rapports de validation

Les rapports ont été régénérés avec le modèle corrigé. Les résultats actuels sont :

- Validation modèle : 10/10 tests passés.
- Robustesse : 8/8 tests passés.
- Biais et équité : 8/8 tests passés.

3.4 Nettoyage des éléments générés

Les fichiers Python temporaires de type `__pycache__` ont été retirés des livrables. Ils ne sont pas utiles pour l'entreprise et peuvent polluer le dépôt.

4. Ce que nous avons créé

4.1 Dossier de rendu par équipe

Un dossier rendu/ a été créé pour rendre le projet plus lisible par rôle :

- rendu/infra/ : choix Ollama, URL du serveur et commandes de vérification.

- rendu/devweb/ : lancement et utilisation de l'interface de chat.
- rendu/ia/ : validation du modèle financier et travail expérimental médical.
- rendu/data/ : datasets analysés, nettoyés et préparés.
- rendu/cyber/ : audit sécurité, tests de robustesse et tests de biais.

4.2 Preuve pour le LoRA médical expérimental

Le modèle médical n'est pas destiné à la production. Il sert à démontrer une capacité R&D de fine-tuning. Un fichier de preuve a été ajouté : rendu/ia/medical-lora-proof.md.

Il récapitule la commande d'entraînement, les métriques conservées et les résultats d'évaluation.

4.3 Documentation de formation

Le présent document sert de support pour expliquer le projet à une audience entreprise : direction, responsables métiers, sécurité, data et équipes techniques non spécialisées en IA.

5. Comment utiliser l'assistant au quotidien

Étape 1 : démarrer le serveur IA

Le serveur d'inférence utilisé est Ollama. Il doit exposer le modèle techcorp-phi35-financial localement.

Commande de vérification : `python3 scripts/check_ollama.py`

Cette commande confirme que le serveur répond et que le bon modèle est disponible.

Étape 2 : lancer l'interface

Commande : `python -m streamlit run app/streamlit_app.py --server.address 127.0.0.1 --server.port 8502`

L'interface est ensuite accessible à l'adresse : `http://127.0.0.1:8502`.

Étape 3 : poser des questions adaptées

L'assistant est fait pour des questions de finance, budget, investissement, analyse business et économie. Il n'est pas fait pour :

- récupérer des mots de passe, clés API ou informations internes ;
- remplacer un professionnel réglementé ;
- donner des conseils médicaux ;
- exposer le serveur à Internet sans contrôle d'accès.

6. Bonnes pratiques pour l'entreprise

Gouvernance

- Nommer un propriétaire fonctionnel de l'assistant IA.
- Définir les usages autorisés et interdits.
- Conserver un historique des versions du modèle et des rapports de tests.

Sécurité

- Ne jamais entraîner un modèle sur des données contenant des secrets.
- Nettoyer les datasets avant tout fine-tuning.
- Tester régulièrement les prompts sensibles : secrets, injection, backdoor, biais.
- Ne pas exposer Ollama directement sur Internet.

Qualité

- Relancer les tests après chaque changement de modèle ou de prompt système.
- Faire relire les réponses sensibles par un expert métier.
- Informer les utilisateurs que l'assistant est un outil d'aide, pas une source d'autorité absolue.

7. Limites connues

- Les tests de biais et de robustesse sont des tests de démonstration, pas un audit exhaustif.
- Le modèle médical reste expérimental et ne doit pas être utilisé en production clinique.
- L'adapter LoRA médical local n'est pas versionné dans Git car le dossier outputs/ est ignoré.
- Une exposition réseau nécessiterait une authentification, une supervision et des journaux adaptés.
- Le modèle peut encore produire des formulations imparfaites ; les réponses critiques doivent être relues.

8. Prochaines étapes recommandées

- Priorité haute : mettre l'interface derrière une authentification si elle sort du poste local.
- Priorité haute : mettre en place une revue périodique des datasets avant entraînement.
- Priorité moyenne : créer un jeu de tests plus large pour robustesse et biais.
- Priorité moyenne : documenter une procédure de mise à jour du modèle.
- Priorité basse : ajouter des graphiques de loss pour le fine-tuning médical.

9. Glossaire rapide

- Ollama : outil permettant d'exécuter localement un modèle de langage.
- Modèle : moteur IA qui génère les réponses.
- Prompt : message envoyé à l'IA.
- Backdoor : comportement caché déclenché par une phrase ou condition particulière.
- LoRA : méthode légère pour adapter un modèle à un domaine spécifique.
- Dataset : ensemble de données utilisé pour tester ou entraîner un modèle.
- Robustesse : capacité du système à résister à des demandes anormales ou malveillantes.

Document généré pour accompagner la remise du projet TechCorp AI Chat. Il complète les rapports techniques présents dans le dossier docs/.